INFORME DE REMEDIACIÓN · TESINA

De 6 a 0 vulnerabilidades

Auditoría de dependencias npm sobre `votacion-backend` (Fastify + Prisma + Redis + ethers.js/BFA), el servicio que firma y verifica la autenticación del sistema de votación electrónica de la FING.

Fecha: **2026-09-02** Alcance: **votacion-backend** Herramienta: **npm audit**

Entorno: **Windows · Node v24.15.0**

6 → 0	8	3	0
Vulnerabilidades	Paquetes actualizados	Archivos de código ajustados	Regresiones detectadas

01 · PUNTO DE PARTIDA

Qué encontró `npm audit`

Seis vulnerabilidades agrupadas en tres cadenas de dependencias, ninguna en código propio.



`fast-jwt ≤6.2.3` → `@fastify/jwt ≤9.0.1` CRÍTICA

- **Bypass de autenticación:** secret HMAC vacío aceptado por el resolver asíncrono de claves
- **Validación de `iss` incompleta** en los claims del token
- Acepta extensiones de header `crit` desconocidas (viola RFC 7515)
- Fix incompleto de confusión de algoritmo vía clave RSA con espacios al inicio
- Confusión de identidad por colisiones en `cacheKeyBuilder`
- RegExp con estado (`/g`) → validación de claims no determinística (DoS lógico)

`fastify ≤5.12.0` + `find-my-way ≤9.6.0` ALTA

- DoS por asignación de memoria no acotada en `sendWebStream`
- Bypass de validación de body vía carácter tab en `Content-Type`
- `request.protocol`/`host` falsificables vía headers `X-Forwarded-*`
- Bypass de validación de schema por coerción de primitivos raíz
- DDoS vía HTTP/2 en el router (`find-my-way`)

`uuid <11.1.1` → `node-cron 3.0.2–3.0.3` MODERADA

– Falta chequeo de límites de buffer en `uuid` v3/v5/v6 cuando se provee un buffer propio

02 · CRITERIO

¿Arreglar o solo documentar?

La tesina no busca demostrar un backend a prueba de auditorías — busca demostrar que votar sobre Blockchain Federal Argentina es viable. Con esa prioridad, no toda vulnerabilidad merece el mismo esfuerzo.

> *Revisando el uso real del JWT en `auth.plugin.ts`/`auth.service.ts`: el secret es un string estático validado por Zod (mínimo 32 caracteres), sin resolver asíncrono, sin `iss`/`crit` custom, sin `cacheKeyBuilder` propio — ninguno de los 6 CVEs de `fast-jwt` es explotable con esta forma de uso.*

Aun así, se decidió corregir las tres cadenas completas: `@fastify/jwt` ≥9 exige Fastify v5, así que el arreglo "barato" (Fastify/node-cron) arrastraba igual el mismo trabajo que el crítico — separarlos no ahorraba nada. Y para la tesina pesa más poder decir *"se detectó una vulnerabilidad crítica y se resolvió"* que explicar por qué no hacía falta.

03 · EJECUCIÓN

Proceso de remediación

Cinco pasos, cada uno disparado por lo que rompió el anterior.

1 **`npm audit fix --force`**

`@fastify/jwt` 8.0.1→10.2.2, `fastify` 4.28.1→5.12.1, `node-cron` 3.0.3→4.6.0. `npm audit` pasa a reportar 0 vulnerabilidades — pero solo tocó paquetes con CVE propio.

2 **El resto del ecosistema Fastify quedó pisado**

`@fastify/cors`, `@fastify/helmet`, `@fastify/rate-limit`, `fastify-plugin` y `pino` no tenían vulnerabilidad propia, así que `audit fix` los ignoró — pero seguían fijados a versiones para Fastify v4. Hubo que subirlos a mano.

PAQUETE	ANTES	DESPUÉS	POR QUÉ
`@fastify/cors`	`9.0.1`	`11.3.0`	Fastify 5 exige ≥10.x
`@fastify/helmet`	`11.1.1`	`13.1.1`	Fastify 5 exige ≥12.x
`@fastify/rate-limit`	`9.1.0`	`11.2.0`	Fastify 5 exige ≥10.x

PAQUETE	ANTES	DESPUÉS	POR QUÉ
`fastify-plugin`	4.5.1	6.0.0	Ya lo traía @fastify/jwt como transitiva

3 `npm run typecheck` → 4 errores en 2 archivos

Se redujeron a 2 causas reales, las dos por cambios de API de Fastify v5 (no por lógica rota):

src/plugins/error-handler.plugin.ts

```
app.setErrorHandler(
~~(error, req, reply) => {~~

(error: FastifyError, req, reply) => {

  if (error.validation) { ... }   // antes: 'error' era 'unknown' por default en v5
```

src/app.ts

```
const app = Fastify({

~~  logger,                          // v5: 'logger' ahora solo acepta config, no una instancia~~

  loggerInstance: logger,           // instancia real de Pino (con redacción de passwords)

});
```

src/app.ts

```
~~export async function buildApp(): Promise<FastifyInstance> {~~

export async function buildApp() {

  // loggerInstance hace que el tipo real ya no sea FastifyBaseLogger
  // genérico, sino el logger de Pino concreto — se deja inferir.
```

4 Primer arranque real: `FST_ERR_LOG_INVALID_LOGGER_CONFIG`

El error de tipos del paso 3 anticipó exactamente esto: pasar la instancia de Pino en `logger` ahora tira en runtime, no solo en TypeScript. Con el fix de `loggerInstance` ya aplicado, el servidor levantó limpio.

5 Verificación end-to-end contra el server real

Con datos del seed, sin mocks.

```
PS> curl http://localhost:3000/health
{"status":"ok"} 200

PS> POST /api/auth/login/admin  (admin@fing.uncuyo.edu.ar)
{"token":"eyJhbGci...", "admin":{"id":1,...}} 200
```

```
PS> GET /api/admin/elecciones  — con token
{"creada":[...],"publicada":[...],"finalizada":[...]} 200
PS> GET /api/admin/elecciones  — sin token
{"error":"No autenticado"} 401

PS> POST /api/auth/logout
{"mensaje":"Sesión cerrada correctamente"} 200
PS> GET /api/admin/elecciones  — mismo token, post-logout
{"error":"Sesion expirada. Volve a iniciar sesion."} 401  ← blacklist de Redis ok
```

✓	Login con password incorrecta → mensaje genérico, sin filtrar campo	401
✓	Headers de seguridad (Helmet 13): HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy	presentes
✓	Rate limit (v11): headers `x-ratelimit-*` contando descensos	200/min
✓	CORS preflight contra el origin del frontend admin (`localhost:8081`)	allow-origin ok
✓	Cron job de sincronización de elecciones arranca sin error	cada 1 min

04 · CIERRE

Estado final

RESUELTA	RESUELTA	RESUELTA
`fast-jwt` · `@fastify/jwt`	`fastify` · `find-my-way`	`uuid` · `node-cron`
Bypass de auth por secret vacío — el más grave, resuelto.	DoS y spoofing de protocol/host — resuelto.	Bounds-check de buffer — resuelto.

- **Pendiente, fuera de este informe:** `votacion-frontend-admin` y `votacion-frontend-votante` son proyectos npm independientes — no los afecta este cambio. Última auditoría conocida: 11 vulnerabilidades → 3 tras `audit fix`, con `next`/`postcss`/`sharp` aún sin actualizar (bump de patch, no de major).